

## Задание на практическую работу № 3

Тема работы “Статический и динамический анализ приложения”.

### 1. Динамический анализ.

1. Для любых двух модулей программ из предыдущего задания, имеющих ошибки в коде, осуществите фаззинг входных данных с помощью Jazzer для Java. При необходимости внесите 2 ошибки.
2. Опишите действия по запуску фаззера, основные команды, их смысл.
3. Опишите скорость поиска ошибок, детализацию описания предупреждения об ошибке, а также в чем заключалась ошибка, какие подобранные данные позволили ее выявить. Оцените удобство и эффективность фаззера в контексте поиска ошибок в Вашем коде.

**2. Изучите статические анализаторы из списка “А”: Svsce, PVS-Studio, Coverity, Veracode, SonarQube, а также системы классификации дефектов безопасности “Банк данных угроз безопасности информации” ФСТЭК России [1] и общий перечень дефектов (недостатков) безопасности - MITRE Common Weakness Enumeration (далее - CWE) [2].**

Выберите 2 анализатора для дальнейшей работы: один из списка “А”, другой произвольный, возможно также из списка “А”. Для каждого из анализаторов:

- приведите ссылки для скачивания/описания основной информации;
- опишите основные вехи установки/настройки;
- опишите основные виды статического анализа, который осуществляет выбранный анализатор, страницу, где перечислены основные уязвимости, которые ищет анализатор на данный момент.

### 3. Проведите статический анализ дефектов разработанного ПО.

- Подробно изучите дефекты (при необходимости внесите не менее 2х ошибок), выпишите коды ошибок из двух анализаторов;
- сопоставьте каждой из ошибок ее код в CWE и БДУ ФСТЭК [1];
- укажите, если ошибка входит в топ-25 наиболее опасных ошибок ПО в каком-либо году по версии CWE или других рейтингов;
- выпишите коды и описания предупреждений, которые генерируются анализаторами.
- представьте комплексную информацию по ошибкам в табличном виде;
- оцените и сравните удобство и эффективность анализаторов в контексте поиска ошибок в Вашем коде.

**4. Оформите отчет и загрузите его в форму в курсе.** Временем сдачи задания является время его защиты. Правила оценивания работы, оформления и сроки размещены в курсе.

Структура отчета:

- титульный лист (см. шаблон);
- содержание работы;
- введение;
- описание фаззинг-тестирования, включающее:

- описание фаззера, основных команд;
- последовательность действий по запуску фаззера, настройки окружения;
- описание тестовых программ;
- описание экспериментов по фаззингу, включающее:
  - условия проведения эксперимента (OS, RAM etc),
  - затраты по времени и памяти;
  - итоговая таблица и обсуждение результатов;
- описание статического анализа, включающее:
  - ссылки для скачивания/описания основной информации;
  - основные вехи установки/настройки;
  - основные виды статического анализа, который осуществляет выбранный анализатор;
  - итоговая таблица и обсуждение результатов;
- источники;
- код приложений (если менялся или составлялся).

#### **5. Загрузите приложение с тестами и наборы данных в отдельную форму.**

В случае, если объем датасетов превышает 50 Мб. просьба осуществить загрузку особо больших данных в гит-репозиторий и указать на него ссылку в отчете.

#### **Рекомендуемая литература для выполнения задания.**

1. Банк данных угроз безопасности <https://bdu.fstec.ru/threat>
2. Перечень программных ошибок <https://cwe.mitre.org/data/definitions/699.html>
3. Анализ ошибок копирования <https://habr.com/ru/companies/pvs-studio/articles/112276/>
4. Пример анализа ошибок <https://habr.com/ru/companies/pvs-studio/articles/695426/>
5. Различие CWE, CVE, CVSS <https://habr.com/ru/companies/pvs-studio/articles/580474/>
6. Группы ошибок CWE <https://cwe.mitre.org/data/definitions/699.html>